AssetTrust v0.58

Seeded tenant-isolation security validation | Engineering checkpoint | 11 November 2026

RELEASE VERDICT: NO-GO - not approved for customer data or commercial deployment

Executive assessment

v0.58 closes a measurable weakness in the database test strategy. Earlier tests verified the presence of PostgreSQL row-level-security (RLS) flags, but a query returning zero records could have been explained by an empty database. The new contract seeds two synthetic organizations and probes tenant isolation through a **separate restricted PostgreSQL login**. This contract has been implemented and safety-tested offline; it has **not been executed against a live PostgreSQL database** in this environment.

What changed

Live seeded RLS contract. New guarded test covers assets, verification cases, evidence and document metadata using independent operator and restricted-runtime connections.

Adversarial read/write coverage. Tests check own-tenant reads, no-tenant reads, cross-tenant UPDATE/DELETE invisibility, blocked INSERT and non-leaking transaction-local tenant scope.

Supervised release preflight. The database/full release runner now rejects a missing or unverified restricted database URL before starting any migration or test stage.

Credential-safe Kali provisioning. The runtime role installer no longer prints GitHub masking commands containing raw credentials on ordinary terminals; local output must be a private regular file.

CI and evidence integration. CI runs v0.58 offline checks before installation and the seeded RLS test after provisioning the non-bypass runtime role, before HTTP tests.

Scope and safeguards

The live contract is limited to an explicitly authorized, disposable loopback **assettrust_ci** or **assettrust_test** database. It commits synthetic fixtures only to let the independent runtime connection observe them, and attempts cleanup on normal exit. An interrupted process may leave disposable fixtures; discard the test database in that case. No SQL migrations were added or changed.

Verification and release blockers

Evidence captured from the v0.58 source checkpoint

Test / control	Observed result
New v0.58 dependency-free tests	15 / 15 PASS
Version suite regression matrix	56 / 56 PASS
SQL migration fingerprints	25 / 25 unchanged
Architecture, CI YAML and syntax checks	PASS (104 TS/TSX files syntax checked)
Current-source secret scan	PASS (2,536 files; no high-confidence matches)
Real PostgreSQL seeded tenant test	NOT RUN
Authentic npm install and full build	BLOCKED / FAILED - dependencies absent
ClamAV, browser/API, Git history and deployment	NOT VERIFIED

Material residual risks

The new two-organization contract will only demonstrate the database behavior **after it is executed successfully on a real PostgreSQL service**. Existing RLS covers seven designated tables in source; other organization-private records need separate analysis. The runtime role currently receives broad test-only CRUD grants, not finalized production least-privilege permissions.

The original repository Git history, real ClamAV scanning, end-to-end browser workflows, application compilation, TLS/SSH posture, secrets/key management, recovery testing and independent penetration review remain unverified. A transaction-local tenant setting is not a defense against arbitrary SQL injection or a compromised database account. AssetTrust must not be described as official government land-title certification without proper authority and integrations.

Required next gate

On a trusted connected Kali machine: generate and review a genuine npm lockfile; run clean **npm ci**, audits and complete API/web builds; apply all 25 migrations to disposable PostGIS; provision the restricted runtime role; run the v0.57 and v0.58 live contracts; complete the HTTP, browser, malware and operational security gates. Retain actual logs and independent signoff before reconsidering a pilot.

This report distinguishes observed offline tests from unrun live validation. Passing the former is not a substitute for the latter.